

Write-Up: OFFSEC - Hash

Eduardo Panizzon

Para esta sala vamos seguir um padrão de resolução:

- 1 - Verificar quais são os possíveis algoritmos de hash usando **hashid** e **hash-identifier**, podemos usar também o hashcat sem a flag -m, assim ele tenta identificar qual o algoritmo da hash.
- 2 - Tentar usar a wordlist rockyou.txt como sugerido no desafio, se o processo demorar muito tentar força bruta.
- 3 - Usaremos o **hashcat** para quebrar as hash's tanto em wordlist (-a 0) quanto em força bruta (-a 3).
- 4 - Já que a dica do desafio diz que pra cada hash um algoritmo diferente foi usado, vamos anotar os algoritmos que encontrarmos para não repetirmos eles.

=====

Para a **primeira** hash, vamos listar os possíveis algoritmos:

MD5 (-m 0) aparece mais vezes como provável algoritmo, agora vamos tentar quebrar.

O comando ficará:

```
hashcat -a 0 -m 0 hash.txt rockyou.txt
```

Rapidamente conseguimos quebrar a hash, o algoritmo era MD5.

=====

Para a **segunda** hash, algoritmos:

SHA-1 (-m 100) aparece mais, vamos tentar.

O comando fica:

```
hashcat -a 0 -m 100 hash.txt rockyou.txt
```

Novamente quebramos muito rápido, o algoritmo era SHA-1.

=====

Terceira hash, a lista fica:

MD5(-m 0)

MD4(-m 900)

MD2(-m ?)

Como MD5 já foi usado para a primeira hash podemos descartá-lo agora, vamos testar primeiro **MD4(-m 900)**.

O comando será:

```
hashcat -a 0 -m 900 hash.txt rockyou.txt
```

O hashcat retornou Status.....: Exhausted, vamos tentar **força bruta**. Sabemos pelo tryhackme que a resposta deve ter **6 caracteres**, vamos montar uma string de força bruta com 6 ?a, o comando fica:

```
hashcat -a 3 -m 900 hash.txt ?a?a?a?a?a
```

Esse comando vai demorar muito para concluir (na minha máquina a estimativa é de 1 hora). Se olharmos a dica vemos que a resposta só contém letras e números, podemos melhorar nossa string. Podemos fazer um carácter específico com **-1 ?l?u?d**, e 6 caracteres ?1, o comando ficará:

```
hashcat -a 3 -m 900 -1 ?l?u?d hash.txt ?1?1?1?1?1?1
```

O tempo estimado caiu para 5 minutos, vamos esperar. Depois de uns minutos temos a nossa senha, o algoritmo era MD4.

Para resolvermos esse sem a dica podemos seguir a estratégia usada na quinta hash deste write-up.

=====

Quarta hash temos um salt, vamos levar isso em consideração para os possíveis algoritmos, a pesquisa será feita no formato **hash:salt**, aqui parece que apenas o hashcat leva em conta o salt, e a lista fica:

sha1(várias opções)

HMAC-SHA1 (key = \$salt) (-m 160)

Como sha1 foi usado na segunda hash, vamos tentar **HMAC-SHA1(-m 160)**. Lembre de adicionar o salt na hash, separando os dois apenas com :.

O comando será:

```
hashcat -a 0 -m 160 hash.txt rockyou.txt
```

Conseguimos quebrar, o algoritmo era HMAC-SHA1.

=====

Quinta e última hash. Os algoritmos podem ser:

SHA-256 (-m 1400)

Haval-256 (-m ?)

SHA3-256 (-m 17400)

Vamos tentar **SHA-256(-m 1400)**.

Comando:

```
hashcat -a 0 -m 1400 hash.txt rockyou.txt
```

Recebemos Status.....: Exhausted, partimos para **força bruta**, sabemos que a senha tem **6 caracteres**. Sem olhar a dica, vamos começar apenas com dígitos, será bem rápido, se não der, passamos para apenas letras maiúsculas, então apenas minúsculas, então

combinações de letras e números, até que o tempo estimado seja muito grande para esperar. Se nenhuma das combinações resolver, partimos para outro algoritmo.

Então primeiro apenas dígitos numéricos:

```
hashcat -a 3 -m 1400 hash.txt ?d?d?d?d?d?d
```

Nada.

Apenas letras maiúsculas:

```
hashcat -a 3 -m 1400 hash.txt ?u?u?u?u?u?u
```

Nada.

Apenas minúsculas:

```
hashcat -a 3 -m 1400 hash.txt ?l?l?l?l?l?l
```

Conseguimos! Fim do CTF!